


PESU Center for
Information Security,
Forensics and
Cyber Resilience




Welcome to

# PES University

Ring Road Campus, Bengaluru




PESU Center for
Information Security,
Forensics and
Cyber Resilience



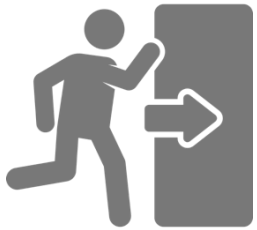

# Information Security - UE23CS343BB6

## Unit 2, Lec 7

# SoC and Threat Intelligence - UE23CS343BB12

## Unit 2, Lec 24

Prof. Prasad Honnavalli, Prof. Preet Kanwal, Dr. Vinodha, Dr Swetha



Emergency Exit



Assembly Point



Washroom



No Chatting



Phones on silent



No Sleeping

# Disclaimer

- ☞ *This presentation is purely educational.*
- ☞ *The views expressed by the presenter is not representation of any organization.*
- ☞ *The views are based on professional experience of the presenter and no liability is accepted by the presenter in the event of any potential or perceived losses resulting from this presentation.*

# A Note on Security

- In this course, you will be exposed to information about security problems and vulnerabilities with computing systems and networks.
- To be clear, you are not to use this or any other similar information to test the security of, break into, compromise, or otherwise attack, any system or network without the express consent of the owner.
- In particular, you will comply with all my instructions when doing the labs.
  - My instructions are in consonance with applicable laws of India and PES University policies.
  - If in any doubt, please consult your professor!
- Any violation is at **YOUR RISK!**
  And may result in severe consequences.

# Cyber Breach at Target



A Harvard Business School Case Study

Do not edit
How to change the design



# What comes to your mind when you hear 'data breach'?

ⓘ The Slido app must be installed on every computer you're presenting from

slido

# Anyone Hacked?

- Anyone experienced a cyber breach?  A data breach?

- Those who haven't experienced one yet! – perhaps you don’t know you have been hacked

- Cybersecurity is very serious and real issue – every individual and company is having to deal with

# Contents


- ☞ Introduction
- ☞ Scope and Impact
- ☞ Timeline
- ☞ Attack Discovery
- ☞ Attack Details
- ☞ Malware Details
- ☞ Missed Opportunities
- ☞ Post Attack Activities
- ☞ Conclusion
- ☞ Q&A
- ☞ Research References

# The case

- This case relates to information systems, cybersecurity, risk management, and executive leadership.

- The case has been used at Harvard and other educational programs.

- To discuss processes that enable or hinder effective detection and prevention of cyber breaches as well as an effective response to detected breaches.

# The case

- Issues relating to cybersecurity raised by the Target breach are not unique:
  - ➢ But the scope and publicity of the attack makes it stand out.

- The case explores the intersection of technical and managerial aspects of cybersecurity issues with added focus on management accountability and response to a highly publicized Incident.

# Pedagogy


Introduction and Assessment of Target's Vulnerability
Accountability of Target's Management
Post Breach response by Target
Lessons regarding Cyber Risk and accountability of Management
Takeaway and update on Target

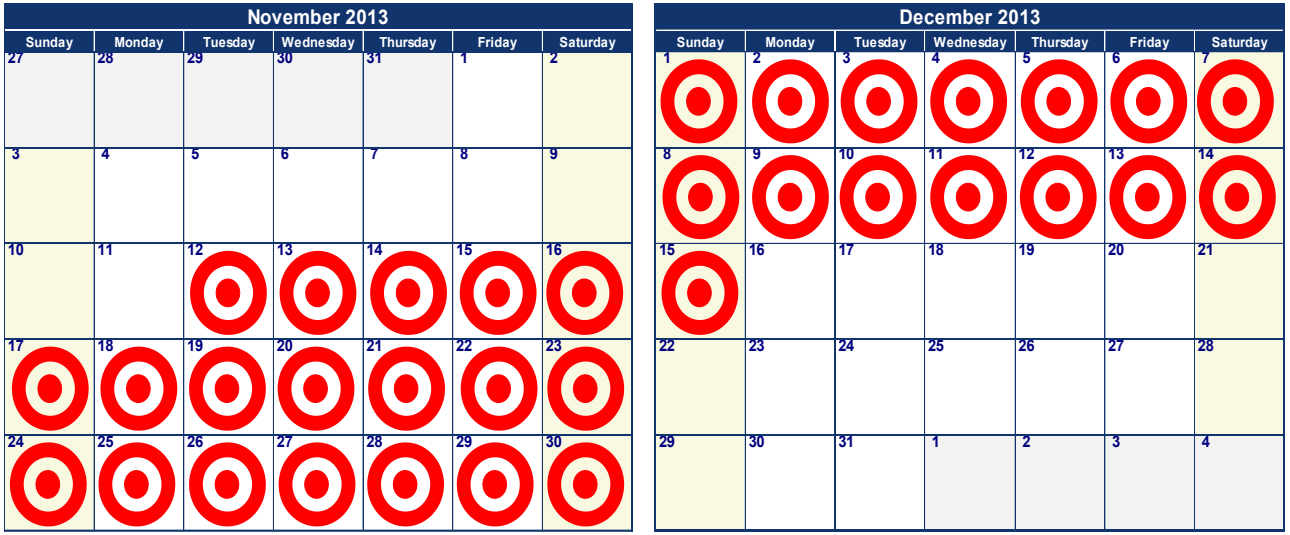
# Scope of impact

- 70 Million Customers impacted
- 40 Million Credit/Debit Cards
- 1 to 3 Million card sold in black market
- $54 Million in Fraud income
- $200 Million+ loss to financial institutions
- $100 Million to upgrade POS
- $252 Million in Cost to Target – Reported in January 2015
- $10 Million settled with customer – Reported in March 2015
- $67 Million settled with Financial Institutions – Reported in August 2015
- $$$ More to come – its not over yet

# A month in Target's network!

- Target Company experienced a cyber attack from Nov 12 through Dec 15, 2013.
- Customer card and personal data was stolen from Nov 27 through Dec 15, 2013.

## a Month in Target's Network

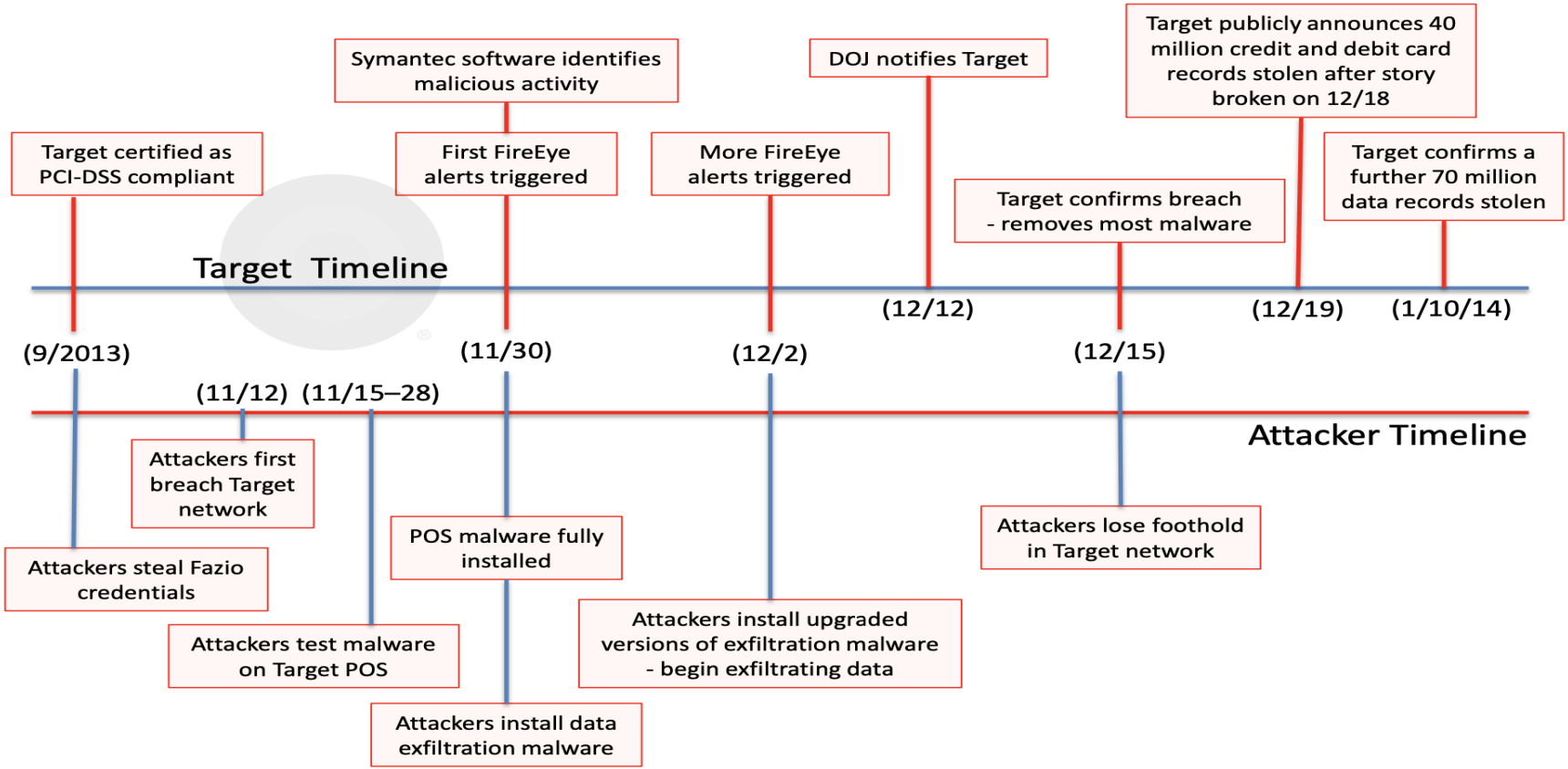



*Source: Forbes.com. The POS terminals at Target were compromised between Wednesday November 27 and Sunday December 15 according to a report by Seculert's Research Lab.*
*Url: http://www.forbes.com/sites/anthonykosner/2014/01/17/researchers-report-exact-timeline-of-massive-target-data-breach/*

# Target - Time Line of the Attack

| September | November 15 | November 27 | November 30 | December 2 | December 12 | December 15 |
|---|---|---|---|---|---|---|
| Attackers compromised Fazio Mechanical Services. | Attackers broke into Target's network and tested malware on POS machines. | Attackers began to collect credit card data. | POS malware fully installed.<br><br>Attackers installed data exfiltration malware.<br><br>Symantec and FireEye alerts triggered. | Attackers began to move credit card data out.<br><br>Additional FireEye alerts triggered. | Department of Justice notified Target. | Target removed most malware. |

# A Timeline of the Target Data Breach



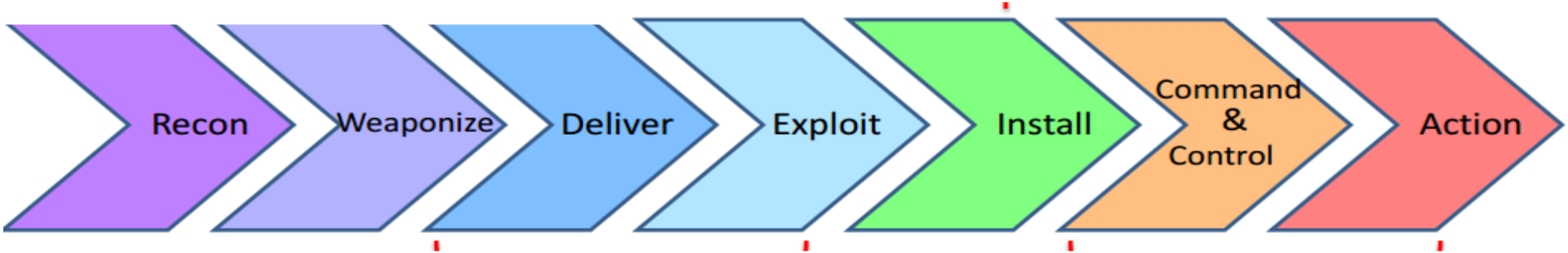
# Was Target Unlucky?

- Complexity of retail systems:
- Lack of generally accepted external standards:
- Constant preparation vs. one-off attacks:
- Target was unlucky to be the first “big” hack:

# Frameworks

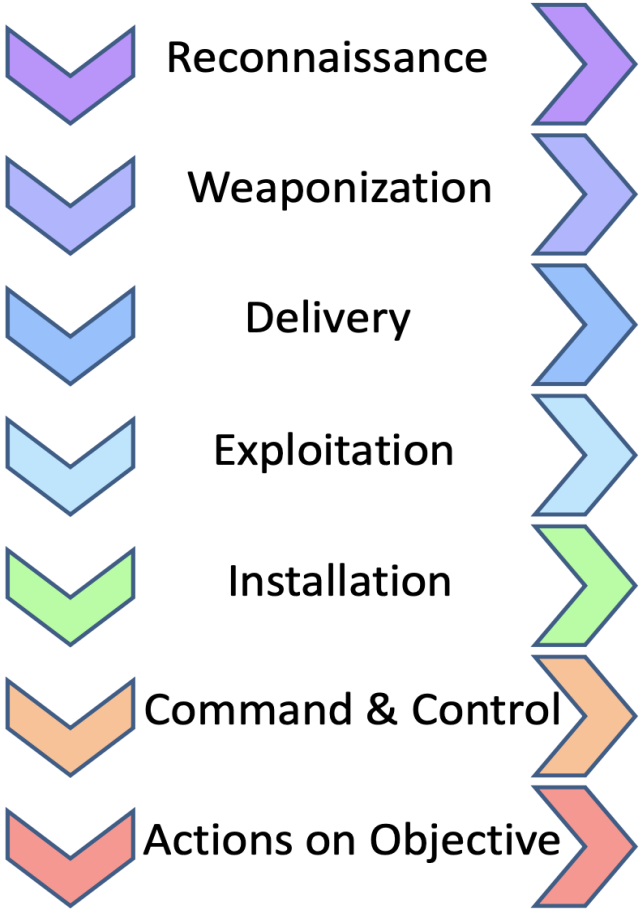
To analyze Attacks and Improve Defense

# The Intrusion Kill Chain




*Source: Committee on Commerce, Science, and Transportation. www.commerce.senate.gov. Target's Possible Mis*
*Url: http://www.commerce.senate.gov/public/_cache/files/24d3c229-4f2f-405d-b8db-a3a67f183883/23E30AA955B5C00FE57CFD7096215926.2014-0325-target-kill-chain-analysis.pdf*

# Phases of the Intrusion Kill Chain




Research, identification, and selection of targets

Pairing remote access malware with exploit into a deliverable payload (e.g. Adobe PDF and Microsoft Office files)

Transmission of weapon to target (e.g. via email attachments, websites, or USB drives)

Once delivered, the weapon's code is triggered, exploiting vulnerable applications or systems

The weapon installs a backdoor on a target's system allowing persistent access

Outside server communicates with the weapons providing "hands on keyboard access" inside the target's network.

The attacker works to achieve the objective of the intrusion, which can include exfiltration or destruction of data, or intrusion of another target

# MITRE ATT&CK

- **MITRE ATT&CK is NOT a tool, NOT a product, and NOT a checklist.**
  - It's a **structured map of how real attackers behave**.
- "ATT&CK answers **HOW attacks happen**, not **WHAT vulnerabilities exist**."
- Imagine every attacker in the world writing down "This is how I break into systems, step by step."
- MITRE just:
  - Observed **real attacks**
  - Documented **repeated patterns**
  - Organized them into a **common language**

# Simple real-world analogy - "Bank Robbery"

| ATT&CK Concept | Bank Robbery | **Technique** |
|---|---|---|
| Reconnaissance | Scout the bank | Reconnaissance |
| Initial Access | Enter the building | Phishing Email |
| Defense Evasion | Disable alarms | Malware |
| Credential Access | Steal keys | Registry Run Keys |
| Privilege Escalation | Open vault | Admin rights |
| Exfiltration | Steal money | Steel IP, Data, |
| Impact | Bankrupt | Ransomware |

| **Defender Role** | **How ATT&CK Helps** |
|---|---|
| SOC Analyst | Detect techniques, not just alerts |
| Blue Team | Find gaps in detection |
| Red Team | Simulate realistic attacks |
| Auditor | Ask "Which techniques can you detect?" |
| Tool Builder | Map controls to techniques |




Good security doesn't stop attacks — it breaks the attacker's path.

https://attack.mitre.org

# The Attack

# How the Attack Happened: A Step-by-Step Breakdown (1/5)

## 1. Initial Access – Compromised Third-Party Vendor

- Attackers **phished credentials** from **Fazio Mechanical**, a **HVAC vendor** that had remote access to Target's network for billing and maintenance.
- The vendor's credentials were **stolen and used to access Target's internal network.**

# Suspicious Login from Third-Party Vendor

**Log Entry (VPN Access Logs)**

```
Timestamp: 2013-11-12 03:15:22 UTC
User: HVAC_Contractor
Source IP: 205.167.88.112
Destination: Target Corp Internal Network
Authentication: Success
```

**Log Entry (VPN Access Logs - Previous Logins)**

```
Timestamp: 2013-11-05 15:42:10 UTC
User: HVAC_Contractor
Source IP: 192.168.1.45 (Chicago)
Destination: Target Corp Internal Network
Authentication: Success
```

1. What anomaly do you notice in the login logs?
   ***Anomaly:*** *The login originated from an unusual IP address.*

2. Why is this important for identifying a potential security breach?
   ***Importance:*** *Indicates a potential credential compromise or unauthorized access.*

3. What security measures could have been implemented to prevent this unauthorized access?
   ***Prevention:*** *Implement geo-restrictions, multi-factor authentication (MFA), and behavioral analytics.*

# How the Attack Happened: A Step-by-Step Breakdown (2/5)

## 2. Lateral Movement – Network Access Expansion

- Once inside, attackers **moved laterally** within the network, eventually gaining access to the **point-of-sale (POS) systems**.
- Lack of **network segmentation** allowed attackers to **move from third-party access to critical systems**(POS terminals).

# Lateral Movement and Privilege Escalation

```
Timestamp: 2013-11-15 02:12:30 UTC
User: HVAC_Contractor
Source IP: 10.20.5.45
Event: Login to Domain Controller
Access: Granted
```

4. Should a third-party vendor have access to a **Domain Controller**? Why or why not?
   **Vendor Access:** No, third-party vendors should have limited access to critical systems.

5. How could network segmentation have prevented this attack?
   **Network Segmentation:** Limits movement within the network to prevent attackers from escalating privileges.

6. What additional security controls could have been used to detect and respond to unauthorized access?
   **Detection Controls:** Implement SIEM (Security Information and Event Management) alerts for unusual access.

# How the Attack Happened: A Step-by-Step Breakdown (3/5)

## 3. Malware Deployment – POS System Infection

- Attackers installed **RAM-scraping malware** (Kaptoxa/BlackPOS) on **thousands of Target's POS systems**.
- The malware **captured credit card details in memory** before encryption and transmitted the stolen data to attacker-controlled servers.

# Malware Installation on POS Systems

**Log Entry (POS System Execution Log)**

```
Timestamp: 2013-11-17 04:45:10 UTC
POS Terminal ID: 4021
Process Executed: PosW.exe
MD5 Hash: 5f4dcc3b5aa765d61d8327deb882cf99
```

**Threat Intelligence Report (Malicious Hashes)**

```
Known Malicious Hashes:
- 5f4dcc3b5aa765d61d8327deb882cf99
- 9e107d9d372bb6826bd81d3542a419d6
```

7. What does the hash tell you about the file that was executed on the POS system?
   **Hash Analysis:** Confirms the file as malware using threat intelligence.

8. How could a company detect and block malware before it executes on critical systems?
   **Prevention:** Use application whitelisting and endpoint security.

9. Why is endpoint detection and response (EDR) important in this scenario?
   **EDR Importance:** Provides real-time detection and response capabilities.

# How the Attack Happened: A Step-by-Step Breakdown (4/5)

## 4. Data Exfiltration – Sending Stolen Information Out

- The attackers **exfiltrated stolen card data** to a server in **Russia**.
- The data was then **sold on dark web markets**, enabling fraud and identity theft.

# How the Attack Happened: A Step-by-Step Breakdown (5/5)

## 5. Detection and Response – Failure to Act Promptly

- Target's **security tools (FireEye, Symantec) did detect** the intrusion and malware installation.
- However, **security alerts were ignored** or not escalated in time.
- The breach was only discovered **when law enforcement and banks noticed fraudulent transactions** linked to Target customers.

# Data Exfiltration to External Server

**Log Entry (Firewall Traffic Logs)**

```
Timestamp: 2013-11-21 23:58:10 UTC
Source: 10.20.5.45 (POS Network)
Destination: 193.104.21.25
Port: 443 (HTTPS)
Data Transferred: 8.7GB
```

**Threat Intelligence Report (Malicious IPs)**

```
Known Malicious IPs:
- 193.104.21.25 (Russia)
- 182.75.123.9 (China)
```

10. Why is this outbound traffic suspicious?

    **Suspicious Traffic:** Large outbound data transfer to a known malicious IP.

11. How could Target have detected and blocked this data exfiltration attempt?

    **Blocking Exfiltration:** Implement Data Loss Prevention (DLP) and outbound traffic monitoring.

12. What role does network monitoring and anomaly detection play in preventing data breaches?

    **Network Monitoring:** Detects anomalies in real time to prevent breaches.

# Causes of the Attack

- **Weak Vendor Security:** The HVAC vendor had **poor cybersecurity hygiene**, allowing attackers to steal credentials via phishing.
- **Lack of Network Segmentation:** Target's network **wasn't properly segmented**, so attackers **could move from third-party access to critical systems**.
- **Failure to Act on Security Alerts:** Target's security tools **detected the attack**, but **alerts were ignored** or **not properly escalated**.
- **Lack of Multi-Factor Authentication (MFA):** If **MFA had been required**, attackers wouldn't have been able to log in with stolen credentials alone.

Do not edit
How to change the design

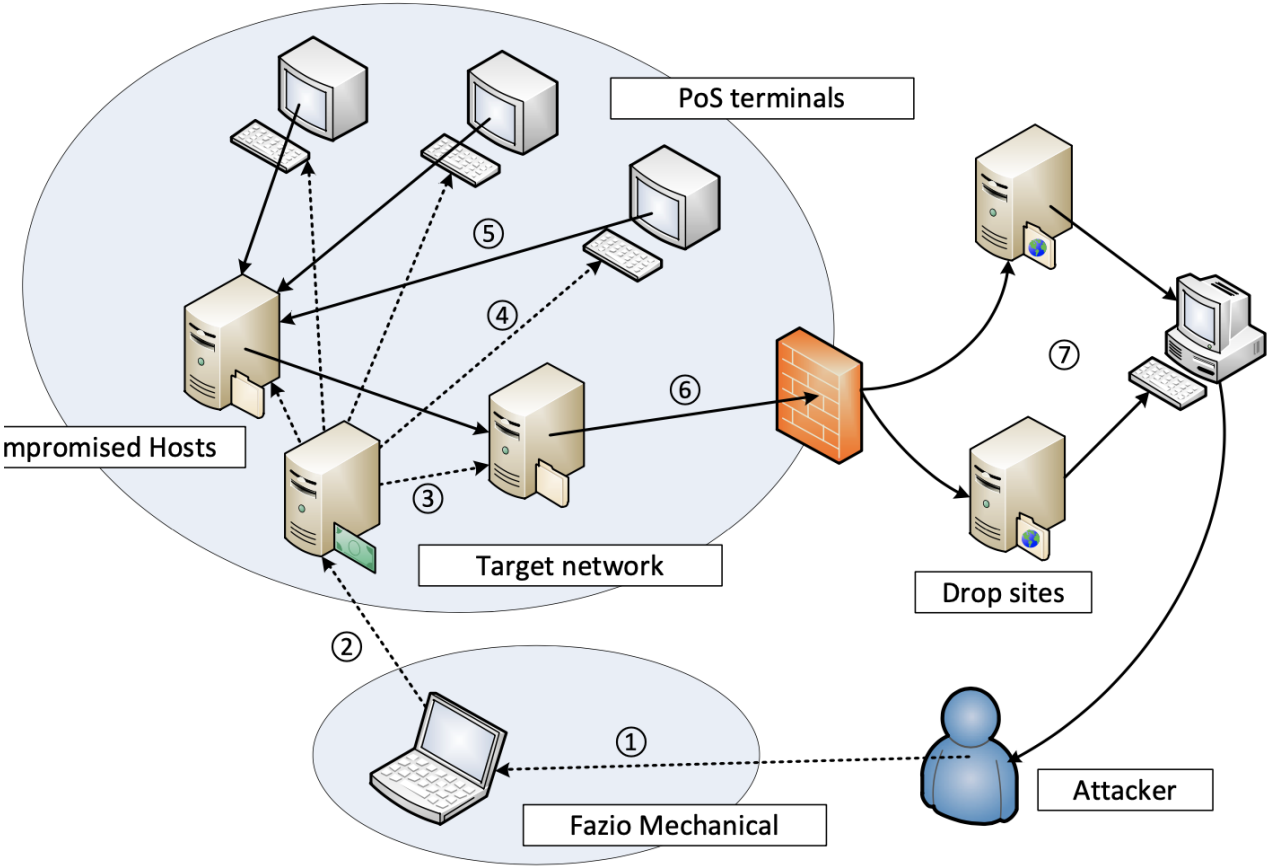


# What was the main cause of the Target data breach?

ⓘ The Slido app must be installed on every computer you're presenting from

slido

# Attack Paths




control path
data flow

1. Phishing attack against Fazio Mechanical Service

2. Accessing the Target network

3. Gaining access to vulnerable machines

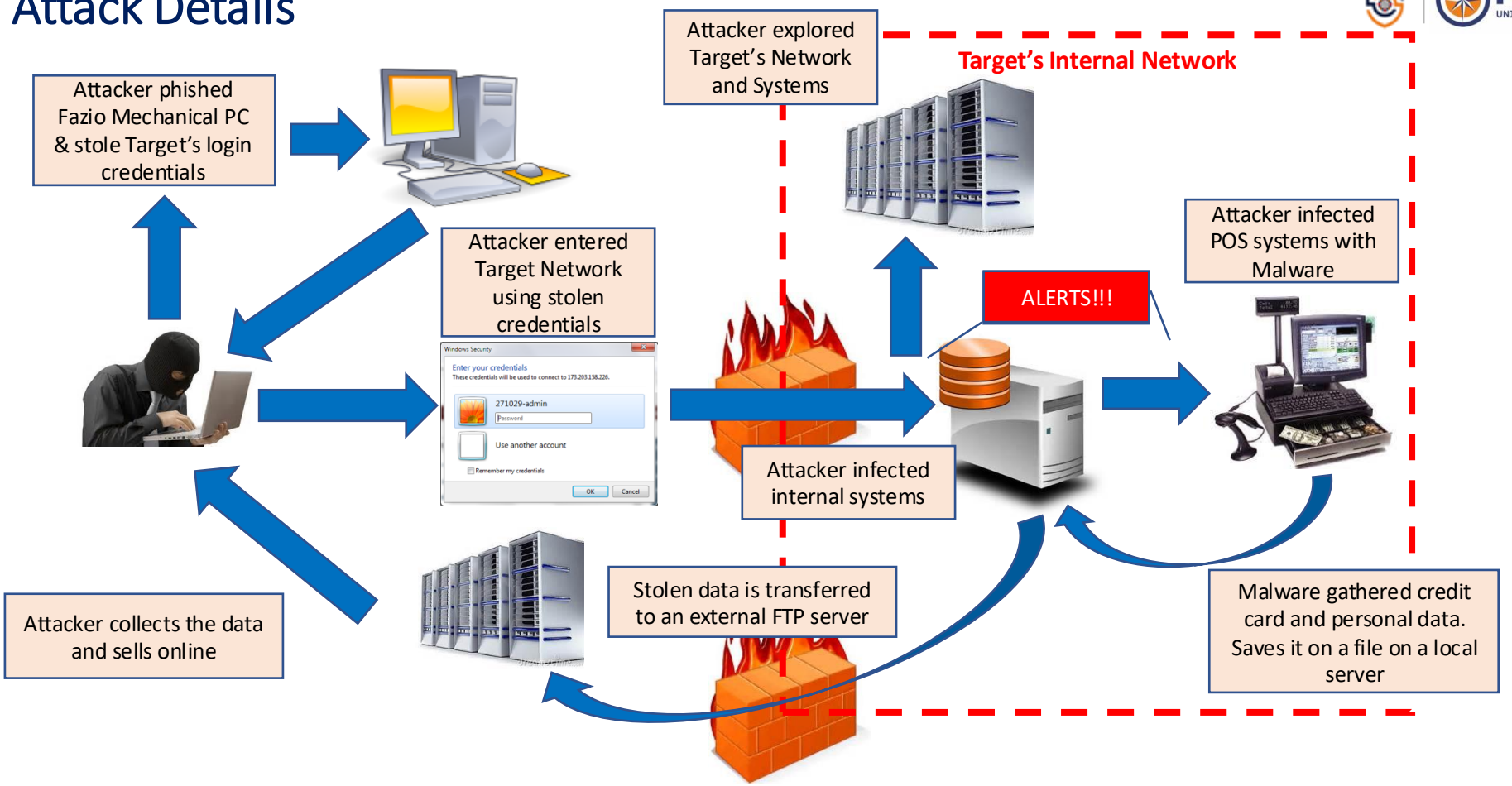
4. Installing malware on PoS terminals

5. Collecting card information from PoS

6. Moving data out of the Target network

7. Aggregating stolen card and person data

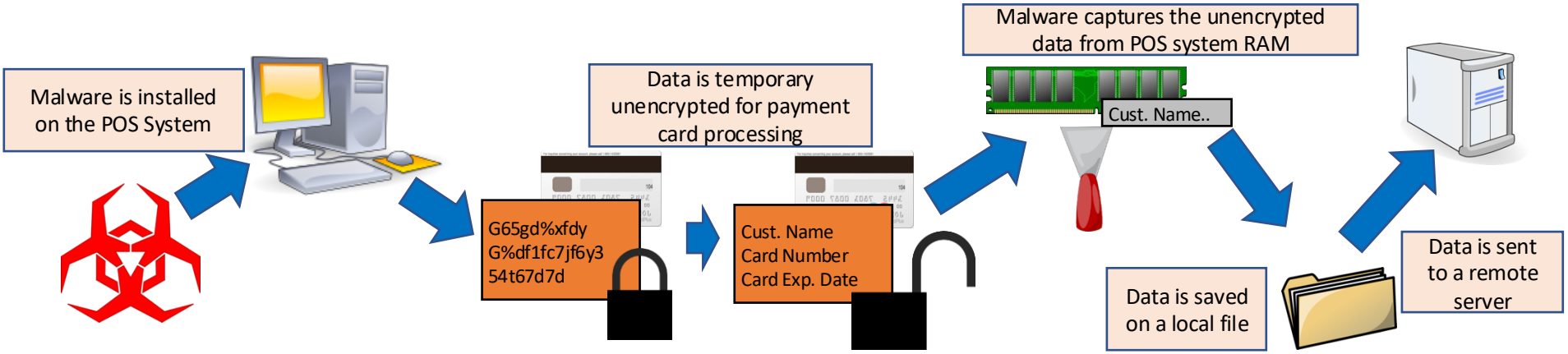
# Attack Details




*Source: IBM Corp. Anatomy of an advanced retail breach Url: http://www.slideshare.net/ibmsecurity/anatomy-of-an-advanced-retail-breach*

# POS Ram Scrapper

- Attackers used a malware from the family of “POS Ram Scrapper” called Black POS
- It captures the card & customer information from the POS terminal’s memory banks during transaction processing and stores it at a local file for later transmission to a remote server
- Vulnerability Areas - Data is briefly unencrypted for card transaction approval and not properly protected (or eliminated) in the memory banks




*Source: websense.com. Point-of-Sale Malware and the seven stage attack model. Url: http://www.websense.com/assets/pdf/Infographic-Security-Labs-2014.pdf*

# Malware complexity

- According to reports by Brian Krebs, a tailored version of the "BlackPOS" malware – available on black market cyber crime forums for between $1,800 and $2,300 – was installed on Target's POS machines. *(Brian Krebs, A First Look at the Target Intrusion, Malware, KrebsOnSecurity (Jan. 15, 2014) (online at http://krebsonsecurity.com/2014/01/a-first-look-at-the-target-intrusion-malware/)*
- This malware has been described by McAfee Director of Threat Intelligence Operations as "absolutely unsophisticated and uninteresting." *Michael Riley, Ben Elgin, Dune Lawrence, and Carol Matlack, Missed Alarms and 40 Million Stolen Credit Card Numbers: How Target Blew It, Bloomberg Businessweek (Mar. 13, 2014) (online at http://www.businessweek.com/articles/2014-03-13/target-missed-alarms-in-epic-hack-of-credit-card-data).*
- This assessment is in contrast with the statement of Lawrence Zelvin, Director of the Department of Homeland Security's National Cybersecurity and Communications Integration Center, who describes the malware used in the attack as "incredibly sophisticated." *(House Committee on Energy and Commerce, Subcommittee on Commerce, Manufacturing, and Trade, Protecting Consumer Information: Can Data Breaches Be Prevented?, 113th Cong. (Feb. 5, 2014).*

# Comparision with other attacks

# Comparison to Other Attacks

| Factor | Target (2013) | SolarWinds (2020) | Colonial Pipeline (2021) |
|---|---|---|---|
| **Attack Type** | Supply Chain Attack via HVAC Vendor | Supply Chain Attack via Software Update | Ransomware Attack via Phishing |
| **Initial Entry** | Stolen vendor credentials(Fazio Mechanical) | Malicious update in SolarWinds Orion | Phishing compromised VPN credentials |
| **Lateral Movement** | Weak segmentation allowed movement to POS systems | Attackers moved across networks using Orion software backdoor | Attackers encrypted key IT systems, affecting OT |
| **Impact** | 40M credit card numbers stolen | 18,000+ companies & US government agencies compromised | Shut down US fuel supply, causing shortages |
| **Security Failure** | Ignored alerts, lack of MFA, no network segmentation | Lack of software supply chain security & zero-trust policies | No MFA for VPN and weak incident response |
| **Response** | Public outrage, lawsuits, CIO & CEO resigned | Large-scale remediation, new federal policies on supply chain security | Colonial paid $4.4M ransom, stricter pipeline regulations followed |

# Key Similarities

- **Third-Party Weaknesses**:
  - **Target**: HVAC vendor was the weak point.
  - **SolarWinds**: Software vendor was compromised.
  - **Colonial Pipeline**: Employee credentials were stolen.

- **Lateral Movement Due to Poor Segmentation**:
  - Attackers **moved from initial access to critical systems** in all three cases.

- **Failure to Detect or Respond in Time**:
  - In **all three attacks**, security tools **detected anomalies**, but responses were **slow or ineffective**.

- **Massive Business and Financial Impact**:
  - **Target** lost **$162M** in costs and lawsuits.
  - **SolarWinds** led to **nationwide security reforms**.
  - **Colonial Pipeline** caused **fuel shortages across the U.S.**

# Lessons Learned

- **Enforce Strong Vendor Security**: Require **MFA** and **least privilege access** for third-party vendors.
- **Implement Network Segmentation**: Prevent lateral movement by **isolating critical systems**.
- **Monitor and Act on Security Alerts**: **Automate escalation** of high-risk alerts to prevent delays.
- **Use Zero-Trust Security**: Assume no user or system is inherently trustworthy.

# Governance, Risks and Compliance

# Was Target Lax?

- Management accountability:
  - Board accountability:
  - Internal control weaknesses:
- Lack of responsiveness to warnings:
- Managing third-party vendor risk:
- Management did not understand the risks associated:

# Management Issues

- The Verizon assessment, conducted between December 21, 2013 to March 1, 2014, notably found *"no controls limiting their access to any system, including devices within stores such as point of sale (POS) registers and servers."*

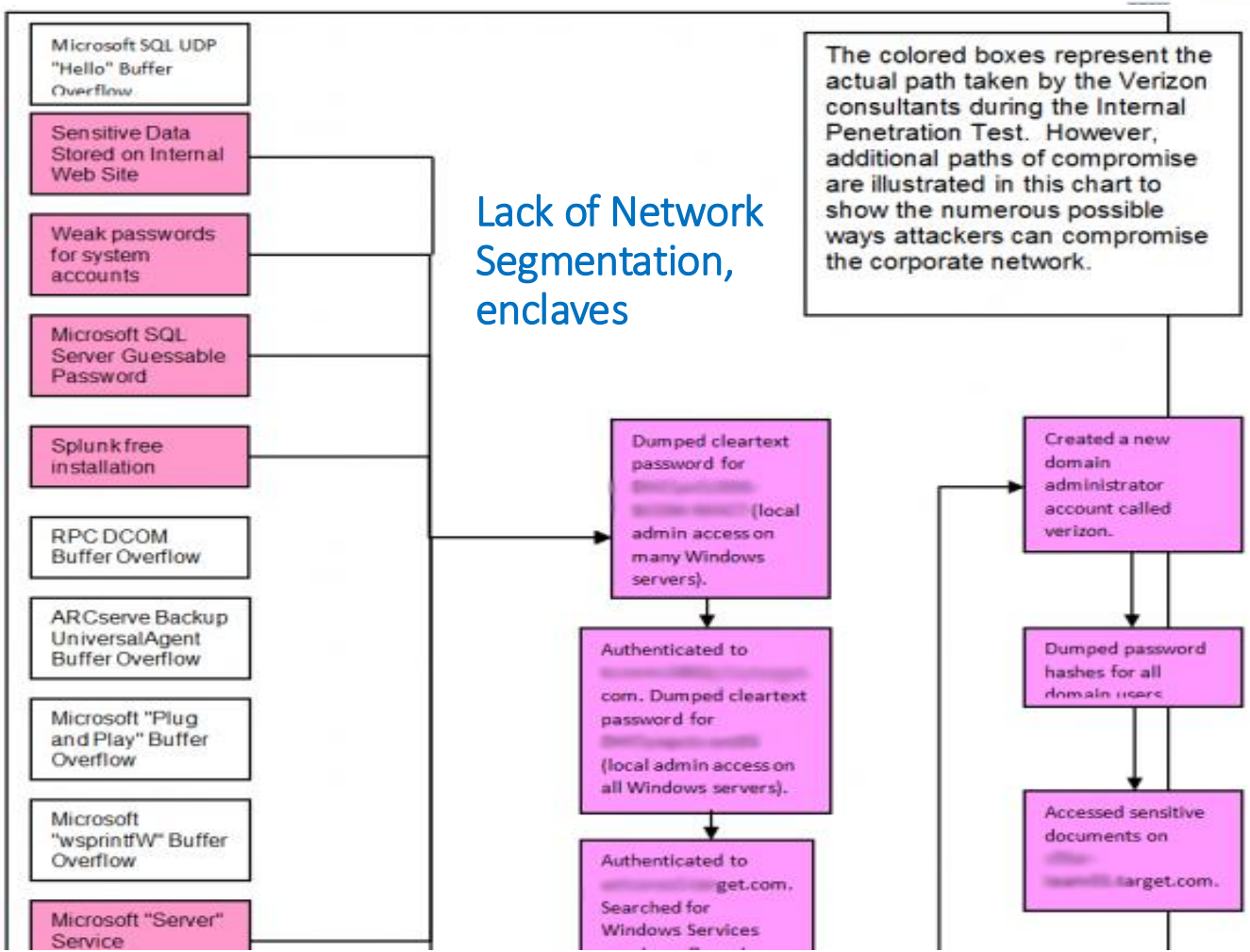
- In February 2014, KrebsOnSecurity was the first to report that investigators had zeroed in on the source of the breach: **Fazio Mechanical**, a small heating and air conditioning firm in Pennsylvania that worked with Target and had suffered its own breach via malware delivered in an email.
  - In that intrusion, the thieves managed to steal the virtual private network credentials that Fazio's technicians used to remotely connect to Target's network.

# A FireEye alert in XML

```
<?xml version="1.0" encoding="utf-8"?>
<alerts appliance="192.168.100.1" msg="extended" product="Web MPS" version="6.2.0.74484" xmlns="http://www.fireeye.com/

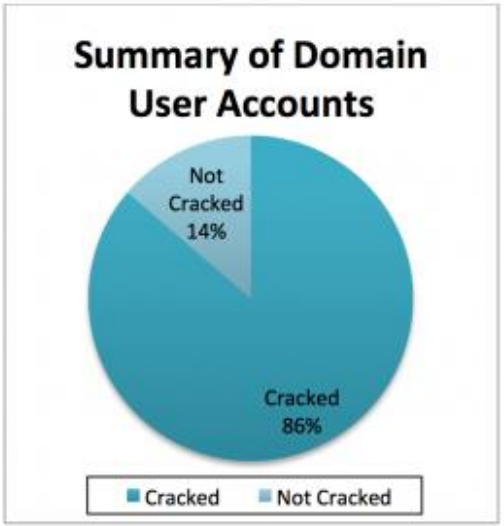
<alert id="1694305" name="malware-object" severity="majr"><explanation analysis="content" protocol=""><malware-detected
<os name="windows" sp="1" version="6.1.7601"/><os_monitor build="84486" date="Feb 28 2013" time="19:22:47" version="6.3
<uac mode="service"><value>Windows Time</value><status>running</status></uac>
<process mode="started"><value>C:\VoiceMail_Houston_(713)4584939.exe</value><pid>2736</pid><ppid>2696</ppid><parentname
<malicious-alert classtype="anomaly-tag"><msg>A new process has been launched</msg><display-msg>Startup behavior anomal
<uac mode="service"><value>Windows Error Reporting Service</value><status>running</status></uac>
<mutex><value/><processinfo><pid>2736</pid><imagepath>C:\VoiceMail_Houston_(713)4584939.exe</imagepath><md5sum>28401b27
<apicall><processinfo><pid>2736</pid><imagepath>C:\VoiceMail_Houston_(713)4584939.exe</imagepath><md5sum>28401b273110fb
<malicious-alert classtype="misc-anomaly"><msg>Debugger awareness detected</msg><display-msg>Process trying to detect t
<mutex><value>\Sessions\1\BaseNamedObjects\DBWinMutex</value><processinfo><pid>2736</pid><imagepath>C:\VoiceMail_Housto
<process mode="started"><value>C:\Windows\System32\svchost.exe</value><pid>2744</pid><ppid>2736</ppid><parentname>C:\Vo
<malicious-alert classtype="misc-anomaly"><msg>Process starting new instance of svchost.exe</msg><display-msg>New servi
<codeinjection mode="create process suspended section mapped code injection" suppressed="false"><source tainted="true">
<malicious-alert classtype="misc-anomaly"><msg>Check for Self Code Injection</msg><display-msg>Check for Self Code Inje
<malicious-alert classtype="misc-anomaly"><msg>Code injection detected</msg><display-msg>Code injection detected</displ
<mutex><value/><processinfo><pid>2744</pid><imagepath>C:\Windows\System32\svchost.exe</imagepath></processinfo></mutex>
<mutex><value>\Sessions\1\BaseNamedObjects\DBWinMutex</value><processinfo><pid>2744</pid><imagepath>C:\Windows\System32
```

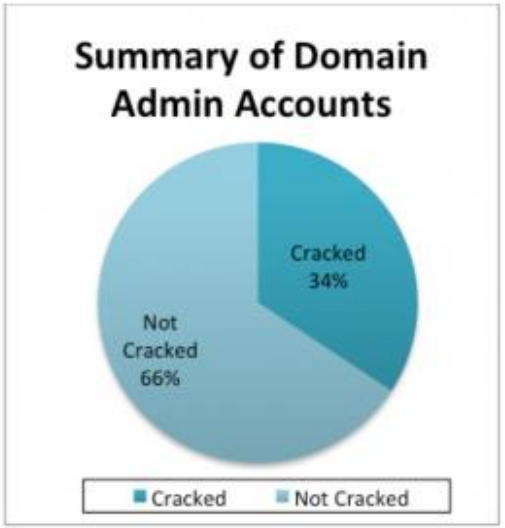
*A high-level graphic showing the various routes that Verizon penetration testers were able to use to get all the way down to Target's cash registers in 2013 and 2014.*



# 86% of Passwords cracked within a week

- Within one week, they were able to crack 472,308 of Target's 547,470 passwords (86 percent) that allowed access to various internal networks, including;
  - target.com,
  - corp.target.com;
  - email.target.com;
  - stores.target.com;
  - hq.target.com;
  - labs.target.com; and
  - olk.target.com.




*Percentages above are based on 472296 of 547435 user passwords and 12 of 35 admin passwords cracked.*

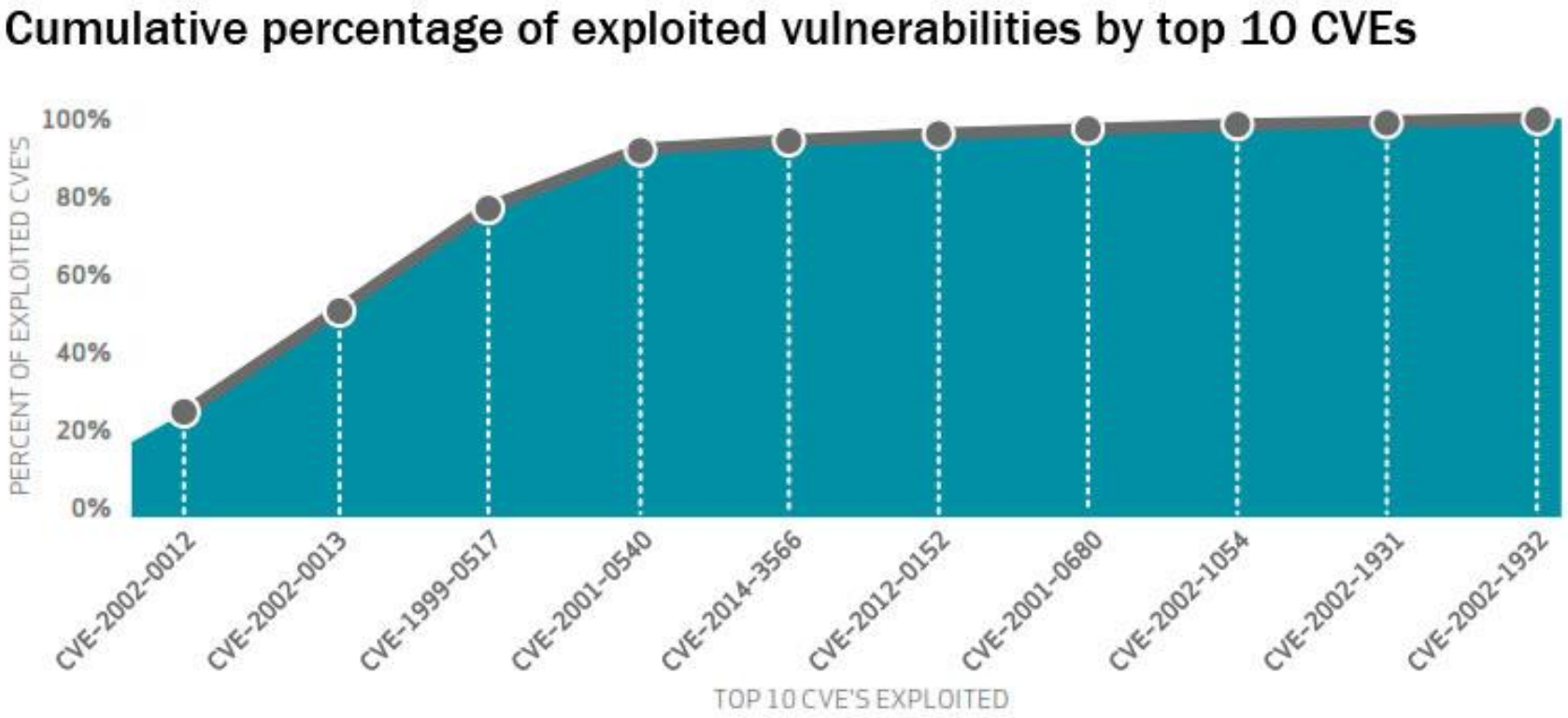
| | |
|---|---|
| **One to six characters** = 83 (0.02%)<br>**One to eight characters** = 224731 (47.59%)<br>**More than eight characters** = 247536 (52.41%)<br><br>**Single digit on the end** = 78157 (16.55%)<br>**Two digits on the end** = 68562 (14.52%)<br>**Three digits on the end** = 28532 (6.04%) | **Only lowercase alpha** = 141 (0.03%)<br>**Only uppercase alpha** = 13 (0.0%)<br>**Only alpha** = 154 (0.03%)<br>**Only numeric** = 1 (0.0%)<br><br>**First capital last symbol** = 60641 (12.84%)<br>**First capital last number** = 95626 (20.25%) |
| **Top 10 passwords** | **Top 10 base words** |
| Jan3009# = 4312 (0.91%)<br>sto$res1 = 3834 (0.81%)<br>train#5 = 3762 (0.8%)<br>t@rget7 = 2260 (0.48%)<br>CrsMsg#1 = 1785 (0.38%)<br>NvrTeq#13 = 1350 (0.29%)<br>Tar#76DSF = 1301 (0.28%)<br>summer#1 = 1174 (0.25%)<br>R6c#VJm4 = 1006 (0.21%)<br>Nov@2011 = 1003 (0.21%) | target = 8670 (1.84%)<br>sto$res = 4799 (1.02%)<br>train = 3804 (0.81%)<br>t@rget = 3286 (0.7%)<br>summer = 3050 (0.65%)<br>crsmsg = 1785 (0.38%)<br>winter = 1608 (0.34%)<br>nvrteq = 1362 (0.29%)<br>tar#76dsf = 1301 (0.28%)<br>qwer = 1166 (0.25%) |
| **Password length (length ordered)** | **Password length (count ordered)** |
| 3 = 1 (0.0%)<br>5 = 4 (0.0%)<br>6 = 78 (0.02%)<br>7 = 81724 (17.3%)<br>8 = 142924 (30.26%)<br>9 = 105636 (22.37%)<br>10 = 64633 (13.69%)<br>11 = 44264 (9.37%) | 8 = 142924 (30.26%)<br>9 = 105636 (22.37%)<br>7 = 81724 (17.3%)<br>10 = 64633 (13.69%)<br>11 = 44264 (9.37%)<br>12 = 19229 (4.07%)<br>13 = 9524 (2.02%)<br>14 = 3874 (0.82%) |

"Top 10" rankings of passwords, lengths, base words, and character set complexities .

# Patchy Patching

- Systems missing critical Microsoft patches
- Running outdated [web server] software such as Apache, IBM WebSphere, and PHP hosted on web servers, databases, and other critical infrastructure which have many known vulnerabilities associated with them.
- In several of these instances where Verizon discovered these outdated services or unpatched systems, they were able to gain access to the affected systems without needing to know any authentication credentials."
- "Verizon and the Target Red Team exploited several vulnerabilities on the internal network, from an unauthenticated standpoint.
  - The consultants were able to use this initial access to compromise additional systems.
  - Information on these additional systems eventually led to Verizon gaining full access to the network — and all sensitive data stored at on network shares — through a domain administrator account."

# Patchy Patching



# Discussions

# What were the strengths and weaknesses of the cybersecurity organizational structure at Target?

- Three teams at Target had interrelated responsibility for data security. These were the
  - Target Information Protection (TIP);
  - Target Technology Services (TTS);
  - Corporate Security and Information Security Investigation

# What were the strengths and weaknesses of the cybersecurity organizational structure at Target?

- Target Information Protection (TIP); Sr. Director to President to CFO
  - Vendor assessment
  - Risk Review
  - Internal employee Direct Security

# What were the strengths and weaknesses of the cybersecurity organizational structure at Target?

- Target Technology Services (TTS); CIO to CFO
  - Internal IT, data centres, network storage, 9000 people
  - SOC
  - RED team / “White hat”

# What were the strengths and weaknesses of the cybersecurity organizational structure at Target?

- Corporate Security and Information Security Investigation; VP to General Counsel
- Cybersecurity program Governance
- Internal and External Auditors
- Board Committees

# What were the strengths and weaknesses of the cybersecurity organizational structure at Target?

- ☞ Lack of single point accountability:
- ☞ The company had lots of systems in place:
- ☞ Segmentation was an issue:
- ☞ Board oversight and feedback seemed limited:
- ☞ But there was nothing that really would have raised alarms:
- ☞ Compliance does not equal preparedness:

# Negligence?

- What might have contributed to the lack of action on the FireEye alerts?
- What do you make of the fact that the CEO was not informed for three days after the FBI alert?
- What is your understanding of the cause of such breaches?

# Lack of action?

- What might have contributed to the lack of action on the FireEye alerts?
- What do you make of the fact that the CEO was not informed for three days after the FBI alert?
- What is your understanding of the cause of such breaches?

# Target's Board is NOT accountable

- The company had reasonable policies and procedures in place:
- External auditors and organizations certified that Target was compliant with industry standards:
- It's the responsibility of the management team:
- Cannot eliminate cyber-breach risk:
- It's a very complex business

# Target's Board is accountable

- Unclear whether the board had ever defined or discussed cyber-risk and the board's role in overseeing it:
- Whatever the procedures in place, this clearly was a major violation. Reputational risk is huge:
- Did not put the right people in place:
- The board needed to be aware of the threat landscape:
- Reactionary response:
- Weaknesses in breach reporting and notifications:

# IS CEO accountable?

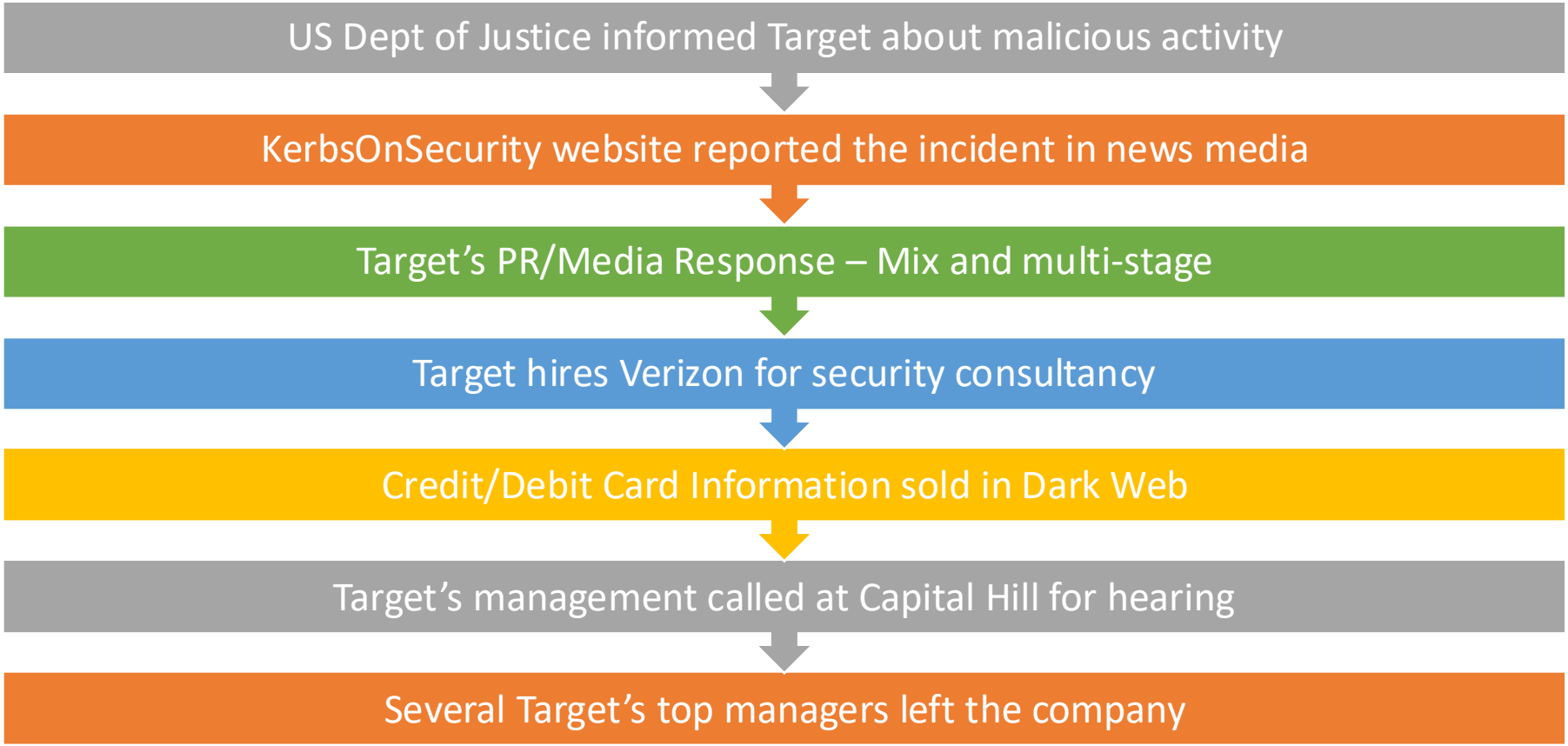
- The CEO can't, and shouldn't, have ownership of cybersecurity:
- Steinhafel isn't responsible for day-to-day cybersecurity, but for serious breaches he should be held accountable:
- In the end, the buck stops with the CEO:
- Show how central cybersecurity is to a business model:

# What could Target have done better in the post-breach period?

- Unclear whether they stuck to a response plan, or even had one in the first place:
- If they had a point person for the response:
- Identified the real risk to the company:

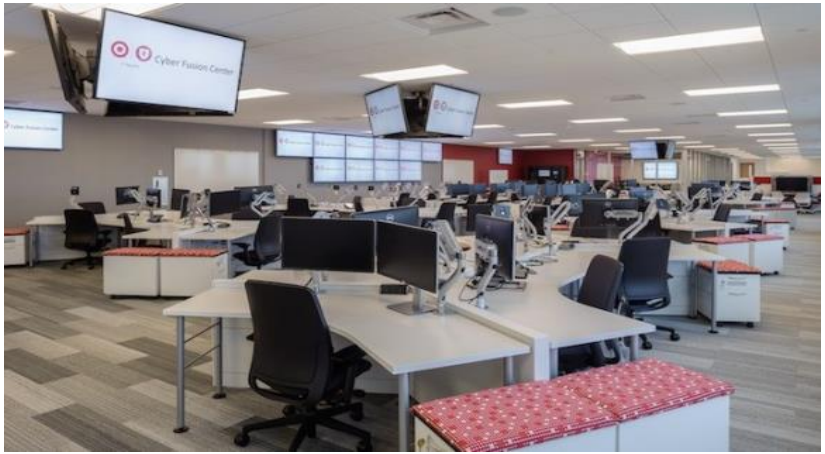
# Post Attack

# Post Attack


US Dept of Justice informed Target about malicious activity
KerbsOnSecurity website reported the incident in news media
Target's PR/Media Response – Mix and multi-stage
Target hires Verizon for security consultancy
Credit/Debit Card Information sold in Dark Web
Target's management called at Capital Hill for hearing
Several Target's top managers left the company

# Target's Strategic Response

- Target reports several changes and improvements to the security of its information systems (separation of key networks, dual authentication, investment in security software, trend analysis, continuous improvement, vulnerability scanning, apply patches) – many details are kept confidential
- Target hires its first CISO
- Verizon recently reported some details how it has helped Target find vulnerabilities




- *Target's "Cyber Fusion Center." Image: Target.com*



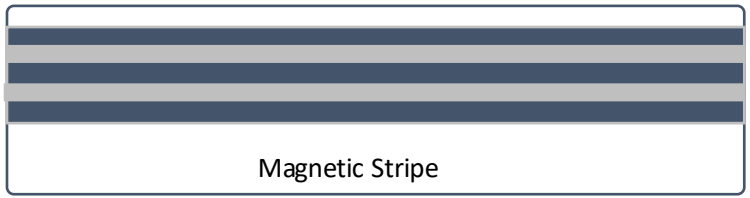

*POS Chip Card Systems*

*Source: Target.com. Inside Target's Cyber Fusion Center. Url: https://corporate.target.com/article/2015/07/cyber-fusion-center*

# Retail Industry & Card Companies Response

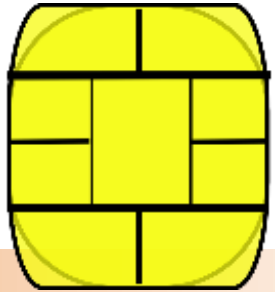
- *Retailers increase compliance with PCI-DSS and improved POS infrastructure*
- *Credit card companies started to transition to the chip cards – Goal 10/1/2015.*









# Evaluating Target's Missed Opportunities

- If Target had implemented "kill chain" cyber security defense methodology, it could have prevented such an attack.
- Establish strict vendor access standards and periodic auditing adherence to standards
- Proper security training (pay attention to alerts and warnings)
  - Training to detect real threats verses false positives, Training to raise proper alarms, and Training for management to pay attention to these alerts
  - Password policy adherence and internal auditing
- Rigorous routine security patches installation and vulnerability remediation program
- Rigorous routine internal tests to discover vulnerabilities
- Observed due care – go above and beyond PCI-DSS standards to encrypt data
- Strategic & Operational oversight
  - Chip card technology recourse in 2004
  - Management attention to alerts

# Research References


1. Target missed multiple data breach warnings, Senate Report says http://www.startribune.com/target-missed-multiple-data-breach-warnings-senate-report-says/252451671/
2. A Kill Chain – Analysis of 2013 Target Data Breach http://www.commerce.senate.gov/public/_cache/files/6e528123-41fc-4c22-a696-a224bbadb6b5/53810A4B7A5AF128030BF310B514BA78.2014-0325-target-kill-chain-analysis.pdf
3. Target CIO resigns http://www.nytimes.com/2014/03/06/business/targets-chief-information-officer-resigns.html
4. Target to Settle Claims Over Data Breach http://www.wsj.com/articles/target-reaches-settlement-with-visa-over-2013-data-breach-1439912013
5. *Threat Encyclopedia – BlackPOS* http://www.trendmicro.com/vinfo/us/threatencyclopedia/malware/TSPY_POCARDL.U
6. 2014 – An Explosion of Data Breaches and PoS RAM Scrapers http://blog.trendmicro.com/trendlabs-security-intelligence/2014-an-explosion-of-data-breaches-and-pos-ram-scrapers/
7. A First Look at the Target Intrusion, Malware http://krebsonsecurity.com/2014/01/a-first-look-at-the-target-intrusion-malware/
8. The Target Breach, Kill Chain Version https://www.securestate.com/blog/2014/08/13/kill-chain


*Note: Above are references used in research in addition to the ones mentioned in slides.*

# Research References


9. $10 Million Settlement in Target Data Breach Gets Preliminary Approval http://www.nytimes.com/2015/03/20/business/target-settlement-on-data-breach.html
10. Inside Target Corp., Days After 2013 Breach http://krebsonsecurity.com/2015/09/inside-target-corp-days-after-2013-breach/
11. Timeline of Target's Data Breach And Aftermath: How Cybertheft Snowballed For The Giant Retailer http://www.ibtimes.com/timeline-targets-data-breach-aftermath-how-cybertheft-snowballed-giant-retailer-1580056
12. Anatomy of the Target data breach: Missed opportunities and lessons learned http://www.zdnet.com/article/anatomy-of-the-target-data-breach-missed-opportunities-and-lessons-learned/
13. Lockheed Martin – Intrusion Kill Chain http://www.lockheedmartin.com/content/dam/lockheed/data/corporate/documents/LM-White-Paper-Intel-Driven-Defense.pdf
14. *Krebs on Security. Cards Stolen in Target Breach Flood Underground Markets. http://krebsonsecurity.com/2013/12/cards-stolen-in-target-breach-flood-underground-markets/*
15. *Krebs on Security. Inside Target Corp., Days After 2013 Breach.* http://krebsonsecurity.com/2015/09/inside-target-corp-days-after-2013-breach/


*Note: Above are references used in research in addition to the ones mentioned in slides.*

# Research References


16. Target's Not-So-Smart Cards The discount retailer could have been the ideal place to introduce chip-enabled credit cards…. http://money.cnn.com/magazines/business2/business2_archive/2004/09/01/379524/
17. Target 'Smart Cards' Will Be Phased Out http://articles.latimes.com/2004/mar/04/business/fi-smartcards4
18. Symantec's report on a brief history of POS malware http://www.symantec.com/connect/blogs/pos-malware-potent-threat-remains-retailers
19. CIO Magazine warned about the BlackPOS malware in March 2013 http://www.cio.com/article/2387200/security0/researchers-find-new-point-of-sale-malware-called-blackpos.html
20. BankInfoSecurity reported about breaches on retail businesses in July 2013. http://www.bankinfosecurity.com/malware-attacks-hawaii-restaurants-a-5910/op-1
21. Target Warned of Vulnerabilities before the Data Breach. http://www.wsj.com/articles/SB10001424052702304703804579381520736715690
22. Target finally gets its first CISO. http://www.computerworld.com/article/2490637/security0/target-finally-gets-its-first-ciso.html
23. Smart Card. https://en.wikipedia.org/wiki/Smart_card
24. EMV FAQs. http://www.creditcards.com/credit-card-news/emv-faq-chip-cards-answers-1264.php


*Note: Above are references used in research in addition to the ones mentioned in slides.*

# Research References


25. Detecting payment card data breaches today to avoid becoming tomorrows headline. http://blogs.cisco.com/security/detecting-payment-card-data-breaches-today-to-avoid-becoming-tomorrows-headline
26. Symantec's report on a brief history of POS malware. http://www.symantec.com/connect/blogs/pos-malware-potent-threat-remains-retailers
27. CIO Magazine warned about the BlackPOS malware. http://www.cio.com/article/2387200/security0/researchers-find-new-point-of-sale-malware-called-blackpos.html
28. BankInfoSecurity reported about breaches on retail businesses http://www.bankinfosecurity.com/malware-attacks-hawaii-restaurants-a-5910/op-1
29. Target Warned of Vulnerabilities Before Data Breach. http://www.wsj.com/articles/SB10001424052702304703804579381520736715690
30. *Researchers Report Exact Timeline Of Massive Target Data Breach* *http://www.forbes.com/sites/anthonykosner/2014/01/17/researchers-report-exact-timeline-of-massive-target-data-breach/*


*Note: Above are references used in research in addition to the ones mentioned in slides.*

# Assignment Question (1/2)

*Based on the case discussions submit your individual written responses as assignment. Your answers must be clearly typed in your own words. Your analysis should be your own and NOT a reproduction of the slides from internet.*

1. Apply MITRE ATT@CK to analyze the Target attack.
   - Where did the attacker **enter**?
   - How did they **execute code**?
   - How did they **move laterally**?
   - What was the **final impact**?

   for each of above, state the tactic and technique(s) likely used.

2. Defender Thinking
   - Where could detection happen earliest?
   - Which step is hardest to detect?
   - Which security control would help most?

# Assignment Question (2/2)

3. What lessons can you draw from this case for prevention and response to cyber breaches?

4. What do you think companies can do better today to protect themselves from cyber breaches and in their post-breach response?

Do not edit
How to change the design



# How useful did you find this presentation?

ⓘ The Slido app must be installed on every computer you're presenting from

slido

# Thank you!

## Follow us



isfcr.pesu



www.isfcr.pes.edu



ISFCR




PESU Center for
Information Security,
Forensics and
Cyber Resilience

